

Security Assessment — Vulnerability Report

CONFIDENTIAL — AUTHORIZED USE ONLY

Report ID	7257bc33	Generated	May 23, 2026
-----------	----------	-----------	--------------

Detailed Findings

#1 [SAST] Missing HSTS Header

HIGH | CVSS
3.1

URL: https://octane.stpi.in/

HTTP Strict Transport Security not set — SSL stripping attacks possible.

#2 [SAST] Missing Content-Security-Policy

HIGH | CVSS
3.1

URL: https://octane.stpi.in/

No CSP header — XSS attacks not mitigated at browser level.

#3 Sensitive Endpoint Accessible Without Auth: /admin

HIGH | CVSS
3.1

URL: https://octane.stpi.in/admin

The path '/admin' returned HTTP 200 with sensitive content without authentication. Keywords found: ['admin']. An unauthenticated attacker can access this resource directly.

#4 Sensitive Endpoint Accessible Without Auth: /admin/

HIGH | CVSS
3.1

URL: https://octane.stpi.in/admin/

The path '/admin/' returned HTTP 200 with sensitive content without authentication. Keywords found: ['admin']. An unauthenticated attacker can access this resource directly.

#5 Sensitive Data Exposed in Response: possible credit card number

HIGH | CVSS
3.1

URL: https://octane.stpi.in/

The response at 'https://octane.stpi.in/' contains possible credit card number. Sensitive values must never be returned in API responses unnecessarily. This data can be captured by a MITM or logged by proxies.

#6 Sensitive Data Exposed in Response: possible credit card number

HIGH | CVSS
3.1

URL: <https://octane.stpi.in/stylesheets/style.css>

The response at '<https://octane.stpi.in/stylesheets/style.css>' contains possible credit card number. Sensitive values must never be returned in API responses unnecessarily. This data can be captured by a MITM or logged by proxies.

#7 Missing Strict-Transport-Security (HSTS) Header

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

The HTTPS endpoint '<https://octane.stpi.in/>' does not send the Strict-Transport-Security header. Without HSTS, browsers may connect over HTTP on subsequent visits, enabling SSL-stripping attacks.

#8 Missing Content-Security-Policy (CSP)

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

The response from <https://octane.stpi.in/> is missing the 'content-security-policy' security header. This reduces browser-level protection against common attack classes.

#9 Missing X-Frame-Options (Clickjacking Risk)

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

The response from <https://octane.stpi.in/> is missing the 'x-frame-options' security header. This reduces browser-level protection against common attack classes.

#10 [SAST] Clickjacking — Missing X-Frame-Options

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

Page can be embedded in iframes, enabling clickjacking.

#11 [SAST] Missing X-Content-Type-Options

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

MIME sniffing not prevented — may enable XSS via file uploads.

#12 [SAST] Cookie Missing HttpOnly Flag

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

Session cookie accessible to JavaScript — theft via XSS possible.

#13 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

OPTIONS request to '<https://octane.stpi.in/>' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#14 Mixed Content — HTTP Resources on HTTPS Page

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

The HTTPS page at '<https://octane.stpi.in/>' loads 3 resource(s) over plain HTTP. Mixed content allows attackers to intercept or modify these resources, potentially injecting malicious scripts or content.

#15 Session Cookie Missing HttpOnly Flag

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

Set-Cookie header at <https://octane.stpi.in/> is missing the 'httponly' attribute.

#16 Subresource Integrity (SRI) Attribute Missing

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/>

Found 4 external script/link tag(s) at <https://octane.stpi.in/> without an integrity attribute. Without SRI, if the external CDN is compromised, malicious code could be injected into your pages.

#17 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/stylesheets/bootstrap.css>

OPTIONS request to 'https://octane.stpi.in/stylesheets/bootstrap.css' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#18 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/stylesheets/style.css>

OPTIONS request to 'https://octane.stpi.in/stylesheets/style.css' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#19 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/stylesheets/responsive.css>

OPTIONS request to 'https://octane.stpi.in/stylesheets/responsive.css' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#20 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/stylesheets/colors/color7.css>

OPTIONS request to 'https://octane.stpi.in/stylesheets/colors/color7.css' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#21 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/stylesheets/animate.compat.css>

OPTIONS request to 'https://octane.stpi.in/stylesheets/animate.compat.css' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#22 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/icon/apple-touch-icon-48-precomposed.png>

OPTIONS request to '<https://octane.stpi.in/icon/apple-touch-icon-48-precomposed.png>' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#23 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/icon/apple-touch-icon-32-precomposed.png>

OPTIONS request to '<https://octane.stpi.in/icon/apple-touch-icon-32-precomposed.png>' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#24 Dangerous HTTP Methods Enabled: TRACE

MEDIUM |
CVSS 3.1

URL: <https://octane.stpi.in/icon/favicon.png>

OPTIONS request to '<https://octane.stpi.in/icon/favicon.png>' revealed dangerous HTTP methods in the Allow header: OPTIONS, TRACE, GET, HEAD, POST. TRACE enables Cross-Site Tracing (XST). PUT/DELETE may allow unauthorized data modification.

#25 Missing X-Content-Type-Options

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

The response from <https://octane.stpi.in/> is missing the 'x-content-type-options' security header. This reduces browser-level protection against common attack classes.

#26 Missing Referrer-Policy

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

The response from <https://octane.stpi.in/> is missing the 'referrer-policy' security header. This reduces browser-level protection against common attack classes.

#27 Missing Permissions-Policy

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

The response from <https://octane.stpi.in/> is missing the 'permissions-policy' security header. This reduces browser-level protection against common attack classes.

#28 Server Technology Version Disclosed: Microsoft-IIS/8.5

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

The 'server' header reveals the server technology and version: 'Microsoft-IIS/8.5'. Attackers can use this to target known CVEs for that specific version.

#29 [SAST] Missing Referrer-Policy

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

No Referrer-Policy — sensitive URL parameters may leak via Referer header.

#30 [SAST] Missing Permissions-Policy

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

Browser APIs (camera, mic, geolocation) may be accessible without restriction.

#31 [SAST] Server Version Disclosure

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

Server header exposes version: Microsoft-IIS/8.5

#32 Session Cookie Missing SameSite

LOW | CVSS
3.1

URL: <https://octane.stpi.in/>

Set-Cookie header at <https://octane.stpi.in/> is missing the 'samesite' attribute.

#33 Password Field Allows Autocomplete

LOW | CVSS
3.1

URL: <https://octane.stpi.in/stylesheets/style.css>

A password input at <https://octane.stpi.in/stylesheets/style.css> does not have `autocomplete='off'`. Browsers may cache credentials and expose them to other users on shared devices.

#34 Password Field Allows Autocomplete

LOW | CVSS
3.1

URL: <https://octane.stpi.in/stylesheets/colors/color7.css>

A password input at <https://octane.stpi.in/stylesheets/colors/color7.css> does not have `autocomplete='off'`. Browsers may cache credentials and expose them to other users on shared devices.